

Record-Level Supervisory Analytics for Security Operations Centres: Controlled Evaluation, Cryptographic Decision Binding, and an External Negative Result

Pratham Kapoor

Manuscript draft; evidence freeze `satsa-evidence-freeze-v2`

Abstract

Supervisors of security operations centres must periodically judge whether monitored organizations detect, investigate, escalate and close security work properly, yet common instruments are self-assessed maturity models and manual record review. We describe SAT-SA, a system that analyses the operational records an organization submits each period (alerts, cases, investigation steps, escalations, dispositions, assets) with 16 deterministic analytical workers, produces findings that cite those records, ranks entities by risk, requires a human supervisory decision, and binds the reviewed state with a post-quantum signed, hash-chained receipt. All results come from frozen, hash-verified experiment bundles. In 5 controlled scenarios the system emitted every declared finding family (recall 1.000, precision 0.417), but simple fixed-threshold and median-deviation rules tied its fast-closure detector. Across 20 generated populations its ranking exceeded random and alert-volume ordering, while a closure-speed heuristic was comparable. Validation matched its declared contract in all 245 perturbed conditions, yet stale and contradictory records were accepted silently. The integrity layer detected all 13 tested mutations, and all 36 injected workflow interruptions recovered. On a real public service-desk incident log, which is not security operations data, the pipeline processed every record, but its risk score was not associated with service-level misses (Spearman correlation -0.11); a failure analysis attributes this mainly to construct mismatch. The evidence supports mechanism-level claims under controlled conditions and feasibility on external data, not effectiveness in real security operations: no human study or expert labels exist, and deployment beyond local processes is unverified.

Keywords: security operations; supervisory analytics; SOC assessment; alert and entity prioritization; human-in-the-loop decision support; evidence provenance; post-quantum signatures; process conformance

1 Introduction

Security operations centres (SOCs) triage large alert volumes under limited analyst capacity [42, 47], and qualitative studies document recurring process problems: false-positive-dominated alarms, mismatched expectations between SOC staff and management, and burnout [3, 22, 39]. When an external body supervises many SOC—for example a national authority responsible for critical infrastructure—it needs to judge periodically whether each monitored organization actually investigated, escalated and closed its work properly. The instruments available for this are mostly maturity self-assessments such as SOC-CMM [46], metric catalogues [12], analyst-performance models [2],

and manual examination of records. Automated assessment of an incident-management process against a reference model has been demonstrated for auditors [30], and the performance of an operational SOC has been measured by injecting synthetic attacks [33].

This paper studies a narrower, record-level question: *can a system analyse the operational records an organization submits each period and produce evidence-cited supervisory findings and priorities, while leaving the decision to a human supervisor and making the reviewed state verifiable afterwards—and how does such a system behave under controlled perturbation and on independent data?* We describe SAT-SA, an implementation of this workflow built for the Smart India Hackathon problem SIH26157, and report what a frozen evaluation of it shows and does not show.

The paper’s emphasis is the evidence rather than the architecture. Every number comes from a hash-verified experiment bundle; negative findings are reported with the same prominence as positive ones. Three of them bound the conclusions: simple baselines match parts of SAT-SA on controlled data; stale and contradictory evidence is accepted silently; and on a real external IT incident log SAT-SA’s risk was not associated with the outcome available there, for reasons we diagnose.

Contributions. We separate contribution types explicitly (Section 9 returns to their strength):

- *Application framing (candidate, low confidence):* SOC supervision posed as record-level analytics for an external supervisor, producing findings that cite the submitted records they depend on. The underlying techniques—conformance-style absence checks, robust deviation rules, peer comparison—are established, and record-based compliance assessment of incident management for auditors exists [30]; the framing is a combination of known parts.
- *Empirical findings:* controlled evaluations of detection against declared labels and simple baselines, one-component ablation, imperfect-evidence robustness, peer-cohort sensitivity, orchestration overhead and recovery, and an external negative result with a failure analysis.
- *Engineering:* a tenant-aware submission, analysis and review workflow with a durable queue and a LangGraph review interrupt.
- *Security capability (integration):* supervisory decisions bound to the analysed state with standard primitives (SHA3-256, ML-DSA-65) and a hash-chained ledger, evaluated with a mutation matrix.
- *Reproducibility infrastructure:* write-once experiment bundles, an evidence freeze with verification, and a paper data layer that generates every reported number.

We make no claim of novelty, superiority, real-world SOC effectiveness or large-scale operational use; Section 10 lists what the evidence does not support.

2 Research Gap and Related Work

Search method. We positioned SAT-SA with a structured search rather than a systematic review. On 27 September 2026 we ran 20 queries covering SOC assessment and metrics, alert prioritization and alert fatigue, security process mining and conformance checking, peer-group analytics, supervisory technology, and tamper-evident and post-quantum audit records. Each query was run against OpenAlex (title and abstract) and Crossref, and the 25 top-ranked records per query and source were retrieved. This gave 656 unique records after deduplication. One screener read

every title and, for 106 records, the abstract; 51 records were included and joined with the 26 sources of an earlier focused review. arXiv throttled the automated queries and was not searched, and records beyond rank 25 were not screened. The absence of a work in this search is therefore not evidence that it does not exist. Queries, counts, screening decisions with reasons, and a comparison matrix are in the supplementary material.

SOC assessment and performance measurement. SOC-CMM scores capability maturity across business, people, process, technology and services domains through a self-assessment tool [46], and CTI-SOC2M2 uses the degree of threat-intelligence integration as a proxy for SOC service maturity [35]. Agyepong et al. review SOC analyst challenges and metrics [1] and weight analyst-performance indicators using a Delphi panel and the analytic hierarchy process [2]; Forsberg and Frantti derive technical SOC metrics through design science [12]. A case study in one academic SOC found that analysts who scored well on key performance indicators did not necessarily further the SOC’s goals [26], which cautions against reading operational metrics as quality. SAIBERSOC evaluates the performance of operational SOC’s empirically by injecting synthetic attacks and measuring outputs such as detection accuracy and time to investigation, with 124 students acting as analysts [33]. Surveys and qualitative studies characterize SOC building blocks, challenges and human factors [22, 39, 40, 47]. These instruments measure maturity, define metrics, explain practice or test a SOC by injection. None of them computes findings from records that a monitored SOC submits to an external supervisor.

Record-based assessment of incident handling. The closest prior work is the compliance assessment system of Palma et al. [30]. It aligns an organization’s incident-management event log with a reference process derived from frameworks such as ITIL and ISO 27035, classifies deviations with a taxonomy, prioritizes them with a cost model, and supports an auditor. It was validated on a benchmark and demonstrated on a public real incident-management log. A companion benchmark compares such process-based assessment models quantitatively [31]. Automated, record-based assessment of how incidents were handled, aimed at an auditor, therefore already exists. Earlier work applied process mining to IT incident management against ITIL [11] and to security audit trails [45]. Recent work represents incident-response activities and responder communications from tool logs as a knowledge graph for process analysis [16], and DomainPrio analyses the population of a SOC’s investigations rather than single alerts [8]. SAT-SA differs from Palma et al. in mechanism and scope rather than in kind. It uses rule-encoded checks over SOC evidence categories (alerts, cases, investigation steps, escalations, dispositions, assets) instead of alignment with a process model. It compares an entity with a declared peer cohort, ranks monitored organizations by a fused risk, and binds the supervisor’s decision to the analysed state cryptographically. We did not compare SAT-SA with that system experimentally.

Alert prioritization and alert fatigue. A large literature ranks alerts or incidents for SOC analysts. Jalalvand et al. review 89 prioritization papers through a human–AI teaming lens [19], and Tariq et al. survey alert-fatigue mitigations [42]. Systems include resource-aware optimization of which alerts to investigate [37], provenance-based triage (NoDoze [18]), guided response trained on customer triage labels [13], large-scale incident ranking [14] and learning to defer to analysts [20]. SAT-SA differs in unit and user: it ranks *monitored organizations* for a *supervisor* from rule-based findings about how work was handled, not individual alerts for an analyst. It is not a competitor to these systems and is not compared with them.

Process analytics and absence detection. Process mining discovers and checks processes from event logs [44]. Conformance checking relates recorded behaviour to a model and exposes skipped or out-of-order activities [7, 34]. SAT-SA’s execution-gap and “negative-space” workers are rule-encoded conformance checks (for example, an acknowledged alert whose case has no investigation step). We treat them as an adaptation of this prior art, not a new technique.

Peer comparison and robust deviation. Peer group analysis flags entities that diverge from similar entities over time [48], in the broader statistical fraud-detection tradition [5]. SAT-SA’s peer worker compares an entity with a declared cohort using the median and the median absolute deviation (MAD) [24], with a minimum cohort size and tenant isolation.

Supervisory technology and human oversight. Financial supervisors increasingly use technology to analyse regulated entities’ data (“suptech”) [6], and human supervisory judgement remains indispensable there, as in SAT-SA’s design. Automation bias in human use of decision support [32] has been reviewed specifically for SOC’s [43]; it motivates keeping the decision with the supervisor, and it was not studied here.

Integrity and provenance of records. Forward-secure and tamper-evident logs detect alteration of recorded history [9, 36]. Practical systems protect operating-system audit logs with trusted execution [29] or combine ratcheting with keystream storage [17], and recent work applies post-quantum primitives to tamper-evident forensic logging in the cloud [15]. W3C PROV provides a provenance vocabulary [25]. SAT-SA does not propose a logging scheme or new cryptography. It composes standard primitives, SHA3-256 [27] and ML-DSA-65 [28], to bind one canonical supervisory record to the authorized decision.

Gap, stated conservatively. Record-based assessment of incident handling [30], supervisory analysis of submitted data [6], peer comparison and tamper-evident records each exist. In the structured search we did not find a work that combines them in the way SAT-SA does: supervisor-side analysis of SOC evidence submissions across monitored organizations, with record-cited findings, peer-cohort comparison, entity risk ranking and a cryptographically bound human decision. This is a combination of established parts, identified by a search with the limits stated above. We therefore offer the framing only as a low-confidence candidate contribution and make no novelty claim.

3 System Architecture

Figure 1 shows the workflow; Table 1 lists the facts the experiments rely on, generated from the source code.

Submission and validation. An analyst of the monitored organization creates a versioned submission for an assessment period and uploads one file per evidence category through an HTTP API (44 routes). Validation parses each record, resolves references (an investigation step must reference an existing case), enforces chronology (closure not before acknowledgement) and stores per-record source provenance (artifact digest, record locator). Hosted validation is all-or-nothing: any rejected record invalidates the version. Artifacts are stored in local storage or an S3-compatible object store; metadata in SQLite or PostgreSQL.

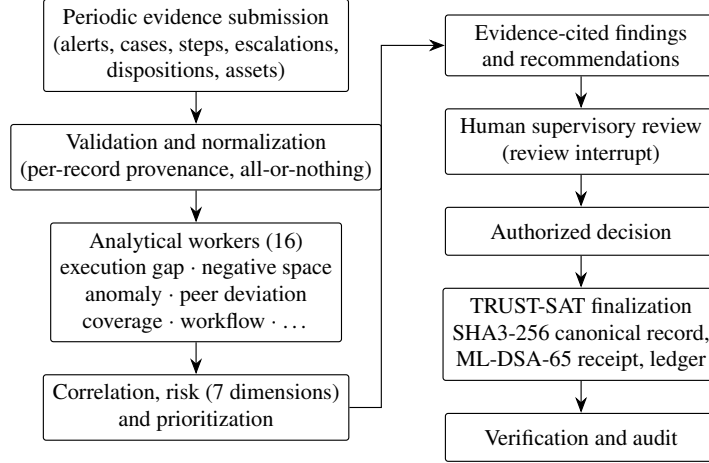


Figure 1: SAT-SA supervisory workflow as implemented. Analytics are deterministic; orchestration (direct worker or LangGraph) sequences the stages and pauses for the human decision.

Analysis. A separate worker process claims queued runs with a lease and executes 16 deterministic analytical workers over the version’s canonical records. Each emits findings with a rationale, statistic, threshold, confidence vector and references to the source records it depends on; a signal finding without evidence references is invalid and is withheld. No worker uses a language model; LangGraph is used only for orchestration. The repository’s capability registry lists 32 components (23 supervisory components and 9 retained machine-learning-operations agents); the experiments exercise the 16 default analytical workers and the workflow around them, not every registered component.

Risk and prioritization. Findings are grouped into 7 weighted dimensions (execution gap, peer deviation, detection gap, negative space, anomaly, investigation quality, escalation discipline). Each dimension’s score saturates in the summed confidence of its findings, and the total (capped at 100) orders entities for supervisory attention. Findings receive recommendations.

Human review and orchestration. Runs can require review. In *direct* mode the worker pauses the run after analysis and recommendations; in *graph* mode a LangGraph graph with 5 nodes (readiness, analysis, recommendations, human review, trust boundary) checkpoints its state and interrupts at the review node [23]. Only a supervisor (or organization administrator) can record the decision; the worker then resumes.

TRUST-SAT finalization and verification. After the decision, the system builds a canonical supervisory document (run, decision, finding, observation, risk and recommendation digests, submission snapshot and source provenance), hashes it with SHA3-256, signs the digest with ML-DSA-65, stores a receipt, and appends the event to a hash-chained ledger. Verification rebuilds the document from live records and checks digest, decision binding, signature and ledger chain (Section 8).

Deployment. The repository contains a container image, a compose topology (PostgreSQL, SeaweedFS object storage, migration and key-initialization jobs, API, worker) and a continuous-integration (CI) job that would run it. All measurements in this paper were taken with SQLite

Table 1: SAT-SA components exercised by the experiments (code facts).

Component	Implementation fact
Analytical workers per run	16 deterministic workers
Risk model	7 weighted dimensions, saturating fusion of finding confidence
Orchestration	direct worker, or LangGraph graph with 5 nodes and a review interrupt
Decision binding	ML-DSA-65 signature over a SHA3-256 canonical digest; hash-chained ledger
Interfaces	44 HTTP API routes; separate analysis worker process
Persistence	SQLite (all measurements); PostgreSQL path implemented, not live-tested

and local storage on one machine; the containerized topology, live PostgreSQL and live S3 storage were not executed (Table 12).

4 Analytical Methodology

The workers fall into rule families that the experiments exercise directly.

Execution gaps. Rules over individual records: an alert closed faster than a severity-specific limit (e.g. critical within ten minutes, above a floor), an acknowledged medium-or-higher alert whose case has fewer than two investigation steps, a critical alert without escalation, repeated shallow investigation patterns, recurring alerts without remediation, and very high closure rates with little investigation. Most fire when at least one qualifying record exists (*existence rules*).

Negative space. Absence of expected work: cases without investigation steps, missing escalations or dispositions, and critical assets without alerts. These are rule-encoded conformance checks [7].

Anomaly and peer deviation. Within-entity outliers are values more than three MADs from the entity’s median [24]; peer deviation compares an entity’s metric with the median and MAD of a declared cohort of at least three peers and flags deviations of two MADs or more.

Coverage and completeness. Assets without monitoring and missing evidence categories.

Fusion. Findings from different rule families that name the same subject are reported as corroborating clusters, which do not change the score; dimension scores saturate in summed confidence, with weights 25 (execution gap), 20 (peer deviation), 15 (detection gap), 15 (negative space), 15 (anomaly), 5 (investigation quality) and 5 (escalation discipline); the entity ranking sorts by the total. A property that matters later: the fusion sums finding confidences and does not use how *prevalent* a problem is within the submission.

5 Experimental Design

Research questions. RQ1: does SAT-SA emit the finding families declared for controlled scenarios? RQ2: how does it compare with simple baselines, and what does each worker contribute? RQ4: how does it behave on imperfect evidence? RQ5: does verification detect tampering with the finalized record? RQ6: how sensitive is the peer worker to cohort size and dispersion? RQ7: what

Table 2: Research questions, experiments, data and independent units.

RQ	Exp.	Data	Independent unit (n)
RQ1 detection	C01	controlled catalog	authored scenario (5)
RQ2 baselines	C01, PR01	closure corpus; generated populations	record (12); population (20)
RQ2 ablation	A01	catalog; populations	scenario (5); population (5)
RQ4 robustness	R01b	perturbed catalog	fixture (5); 245 conditions
RQ5 integrity	T01	one controlled workflow	workflow (1); 14 mutations
RQ6 peer	P01	engineered cohorts	designed cell (96)
RQ7 orchestration	O01, O02	catalog scenario	one machine; 30 paired runs; 36 injected runs
EXT	X02b, X03	UCI-498 IT incident log	group of one organization (50)

do durable orchestration and review cost, and do interrupted runs recover? EXT: does the pipeline run on independent real data, and is its risk associated with an outcome available there? (RQ3, analyst utility, requires a human study that was not run.) Table 2 maps questions to experiments.

Data. *Controlled catalog*: 5 executable scenarios authored with declared finding families and recommended supervisory actions (10 catalog entries in total). Labels are construction labels: they encode what each scenario was built to contain, so agreement shows the mechanism responds to its designed inputs, not that it detects real misconduct. *Generated populations* (PR01): 20 populations of 20 entities each, 5 of them declared pathological, seeded independently. *Engineered peer cohorts* (P01): 96 cells crossing cohort size, dispersion and deviation. *External*: the UCI incident management process event log [4] (dataset 498), a real IT service-desk log of one organization, mapped to SAT-SA categories by an adapter and analysed per assignment group (50 groups with enough incidents). It is IT incident data, not SOC data. Two security datasets were assessed and not used: GUIDE [13] has real triage-graded SOC incidents but no acknowledgement, closure, investigation-step or escalation records (and its download requires an authenticated account), and CIC-IDS2017 [38] contains network flows rather than SOC workflow records.

Baselines. For closure-time detection: fixed threshold, MAD rule, z-score and interquartile-range (IQR) rules, and random. For prioritization: random order (20 populations with repeated random trials), critical-and-high alert volume and a closure-speed heuristic (fastest median closure time first). Externally: random, volume, reassignment rate and slowest median resolution—the last is close to the outcome’s own construct and is included as an upper reference, not a competitor.

Metrics. Precision, recall and F1 against construction labels; precision, recall and normalized discounted cumulative gain (NDCG) [21] within the top $k \in \{10, 20, 30\}$ % of entities (written $P@k$, $R@k$, $NDCG@k$); review volume needed to find all pathological entities; conformance with the validation contract and change of emitted finding families relative to a paired control; wall-clock seconds, database statements and share of time outside the analytics; Spearman ρ against the share of incidents that missed their service-level agreement (SLA-miss rate).

Statistics policy. We report medians; 95th percentiles only when $n \geq 20$; seeded percentile bootstrap intervals [10] only when $n \geq 10$ independent units; paired differences with counts of units where one arm was higher, equal or lower; and no p -values or multiple-comparison claims. The independent unit is stated for each experiment (Table 2); repeated trials within one population or one workflow are not independent. Analyses are descriptive.

Table 3: Closure-time detectors on 12 construction-labelled records (C01).

Detector	TP	FP	FN	Precision	Recall	F1
SAT-SA fast-closure	3	0	0	1.00	1.00	1.00
Fixed threshold	3	0	0	1.00	1.00	1.00
MAD	3	0	0	1.00	1.00	1.00
z-score	0	0	3	–	0.00	–
IQR	0	0	3	–	0.00	–
Seeded random	1	2	2	0.33	0.33	0.33

Undefined ratios shown as –. SAT-SA ties the fixed-threshold and MAD baselines.

Evidence discipline. Each experiment writes a write-once bundle (manifest with code commit and a dirty-tree flag, configuration, raw results, processed metrics, summary) with SHA-256 hashes. The canonical bundles are frozen in `research/evidence/freeze-v2`; superseded bundles (for example X02, replaced by X02b after an ingestion-bookkeeping correction that left every analytical output identical) are kept but not cited for results. Every number in this paper is rendered from these bundles by the paper data layer (Section 11).

6 Results

6.1 Controlled detection and closure-time baselines (RQ1, RQ2)

Over the 5 controlled scenarios analysed in one shared database, SAT-SA emitted every declared finding family (true positives 5, false negatives 0) and 7 undeclared families, giving micro precision 0.417, recall 1.000 and F1 0.588. Its recommended supervisory action matched the declared action in 4 of 5 scenarios. Precision depends on the database layout: analysed one scenario per database (A01), the full worker set had precision 0.556, because cross-entity workers in the shared database see other scenarios’ records. Because labels are construction labels, these figures show the mechanism responds to its designed inputs; they are not accuracy on real SOC data.

On 12 construction-labelled critical closures (3 fast), SAT-SA’s fast-closure detector, a fixed threshold and a MAD rule each reached F1 1.00; z-score and IQR rules found none (recall 0.0) and seeded random reached 0.33 (Table 3). **The detector ties simple baselines**; it offers no detection advantage on this corpus.

6.2 Prioritization against simple baselines (RQ2)

Across 20 generated populations, SAT-SA placed a median 0.800 of the pathological entities in its top 20% and needed a median of 7.0 reviews to find all of them (Table 4, Figure 2). Versus random order its recall@20% was higher in 20 populations and lower in 0 (median paired difference 0.59, 95% bootstrap 0.41 to 0.60); versus alert volume, higher in 20 and lower in 0 (difference 0.40, 0.30 to 0.60). **Against the closure-speed heuristic the comparison is mixed**: recall@20% was higher in 8, equal in 11 and lower in 1 populations (median difference 0.00, interval 0.00 to 0.20); NDCG@30% was higher in 12, equal in 3 and lower in 5; SAT-SA needed fewer reviews in 12 populations and more in 6. A single closure-speed rule captures much of what separates these generator profiles. The populations come from SAT-SA’s own generator, whose pathological profile injects behaviours its detectors target, so the comparison favours SAT-SA by construction; intervals are descriptive and uncorrected.

Table 4: Prioritization on 20 generated populations: medians over populations (PR01).

Method	P@10%	R@20%	NDCG@20%	R@30%	NDCG@30%
SAT-SA	1.000	0.800	1.000	0.800	0.869
Fastest median closure	1.000	0.600	0.832	0.800	0.837
Critical/high alert volume	0.500	0.200	0.246	0.400	0.318
Random (expectation)	0.245	0.201	0.248	0.295	0.276

Top-k budgets are 2, 4 and 6 of 20 entities; estimates are coarse.

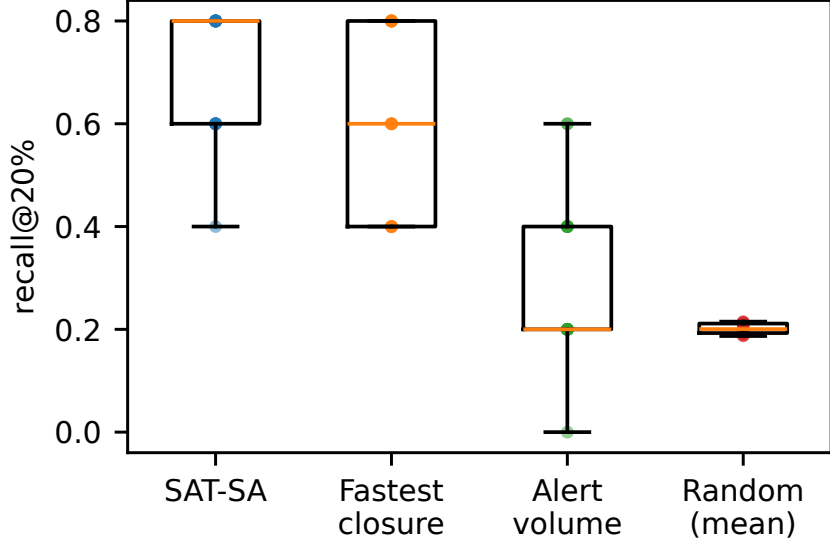


Figure 2: Recall@20% of generator-labelled pathological entities across generated populations (PR01).

6.3 Component ablation (RQ2)

Removing one of the 16 workers at a time (Table 5, Figure 3), fast-closure and negative-space carried recall on the catalog (recall 0.600 and 0.600 without them); removing evidence-completeness gave 0.800. Removing recurring-without-remediation or coverage-gap *raised* precision (0.714, 0.625) because those workers emitted only undeclared families here. On generated populations (five seeds, exploratory), mean recall@20% was 0.760 with all workers, 0.600 without fast-closure and 0.640 without negative-space, while removing anomaly, recurring-without-remediation, coverage-gap or workflow-reconstruction raised it to 0.800: these workers add ranking noise on these populations. Several workers had no measurable effect on these fixtures, which says only that the fixtures do not exercise them.

6.4 Imperfect evidence (RQ4)

Each of the perturbed conditions declared its family, affected records and expected validation outcome before it ran, with one fresh tenant database per condition. Hosted validation matched the declared contract in 245 of 245 conditions with an expectation; 3 were not applicable to their fixture (Table 6). Exact and conflicting duplicates with native identifiers, malformed timestamps, chronology violations and missing columns were rejected (15 malformation and 25 duplication

Table 5: One-worker ablation (A01): scenario micro metrics (5 scenarios) and mean population recall@20% (5 seeds, exploratory). Workers with no change on either view are omitted.

Worker removed	Precision	Recall	F1	Pop. R@20%
(full set)	0.556	1.000	0.714	0.76
– fast-closure	0.429	0.600	0.500	0.60
– recurring-without-remediation	0.714	1.000	0.833	0.80
– negative-space	0.500	0.600	0.545	0.64
– anomaly	0.556	1.000	0.714	0.80
– peer-benchmark	0.556	1.000	0.714	0.72
– coverage-gap	0.625	1.000	0.769	0.80
– case-similarity	0.556	1.000	0.714	0.72
– evidence-completeness	0.500	0.800	0.615	0.76
– workflow-reconstruction	0.556	1.000	0.714	0.80

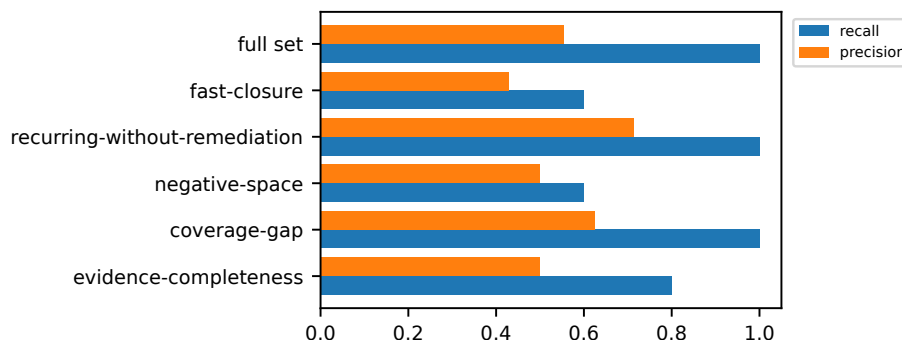


Figure 3: Catalog micro precision and recall with one worker removed; unchanged removals omitted (A01).

conditions).

Two behaviours matter for interpretation (Figure 4). First, validation is all-or-nothing: independent record omission left dangling references and rejected the whole submission in 3, 11 and 14 of the seeded replicates at 10, 25 and 50% omission, whereas referentially consistent omission was never rejected and changed the emitted finding families in 1, 11 and 15 replicates. Second, **stale and contradictory evidence is accepted silently**: all 15 conditions with records outside the assessment period were accepted with no warning and no change to findings or risk (15 unchanged), and contradictory dispositions or a closed case with an open alert produced no finding. SAT-SA implements no period, recency or cross-record consistency validation.

6.5 Peer-cohort sensitivity (RQ6)

Over 96 engineered cells (Table 7, Figure 5), cohorts of two peers never produced a peer finding (the rule requires three). With a tight cohort spread, 7 of the eight subject values were flagged from three peers upward—every value except the one at the cohort median. With a wide spread only extreme slow subjects were flagged at small cohorts (2 at three peers), and fast subjects were flagged only from five peers upward as the MAD narrowed (4 at five peers). The rule is therefore sensitive to cohort dispersion and size, and small or heterogeneous cohorts will miss deviations.

Table 6: Imperfect-evidence conditions by family (R01b).

Family	Conditions	Rejected	Analysed	Families changed	Matches contract
conflict	18	5	13	4	18
control	5	0	5	0	5
duplication	34	25	9	5	34
malformation	15	15	0	0	15
missingness	173	33	140	43	173
staleness	15	0	15	0	no expectation

Staleness has no declared expectation because SAT-SA implements no period or recency validation; all stale conditions were accepted without warning.

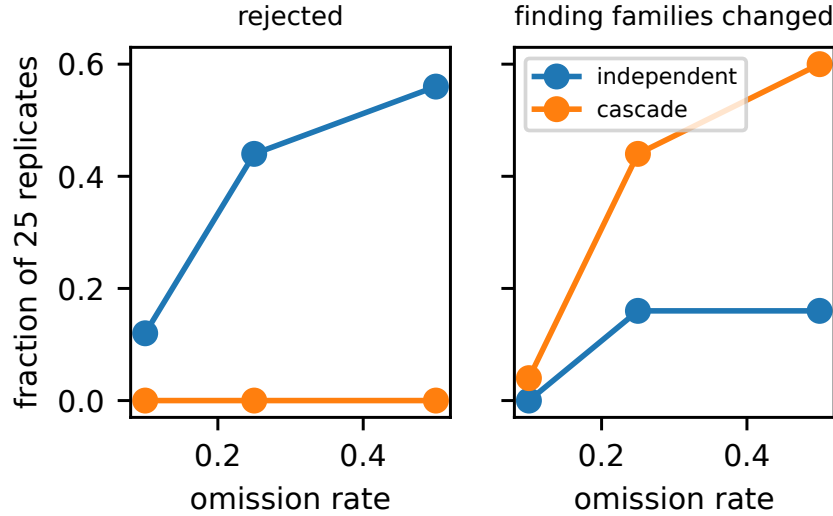


Figure 4: Record omission: independent omission is often rejected by all-or-nothing validation; referentially consistent omission is accepted and changes findings more often as the rate grows (R01b).

6.6 Orchestration cost and recovery (RQ7)

On one machine with SQLite, 30 paired trials per mode (Table 8, Figure 6) gave median processing times, excluding the human decision, of 1.276 s (direct), 1.433 s (LangGraph) and 0.976 s (unreviewed benchmark mode). LangGraph minus direct was a median 0.096 s per workflow (7.5% of the direct median; 95% bootstrap -0.020 to 0.211 s, graph slower in 19 of 30 pairs), with 38 more database statements and 7 checkpoints per run. Findings and risk were identical across modes in every trial. Human review with TRUST-SAT finalization added a median 0.318 s over unreviewed processing (0.176 to 0.569 s); finalization took a median 0.288 s (23% of reviewed processing), receipt verification 0.062 s, and run and finding attestation (0.853 s) was the largest single cost. These are repeated measurements on one machine; the intervals describe that variability only.

Interruptions were injected at 6 points in both modes with 3 trials per cell (Table 9): transient failures and simulated crashes (an exception bypassing the worker’s handler followed by lease expiry) during analysis, before recommendations, at a worker restart during review, and during finalization. **In the evaluated interruption scenarios**, 36 of 36 interrupted runs recovered to completion, and 36 of them produced outputs identical to the uninterrupted reference. Completed stages were

Table 7: Subjects flagged by the peer rule out of 8 subject values per cohort (P01).

Spread	2 peers	3	4	5	6	8
tight	0	7	7	7	7	7
wide	0	2	2	4	3	3

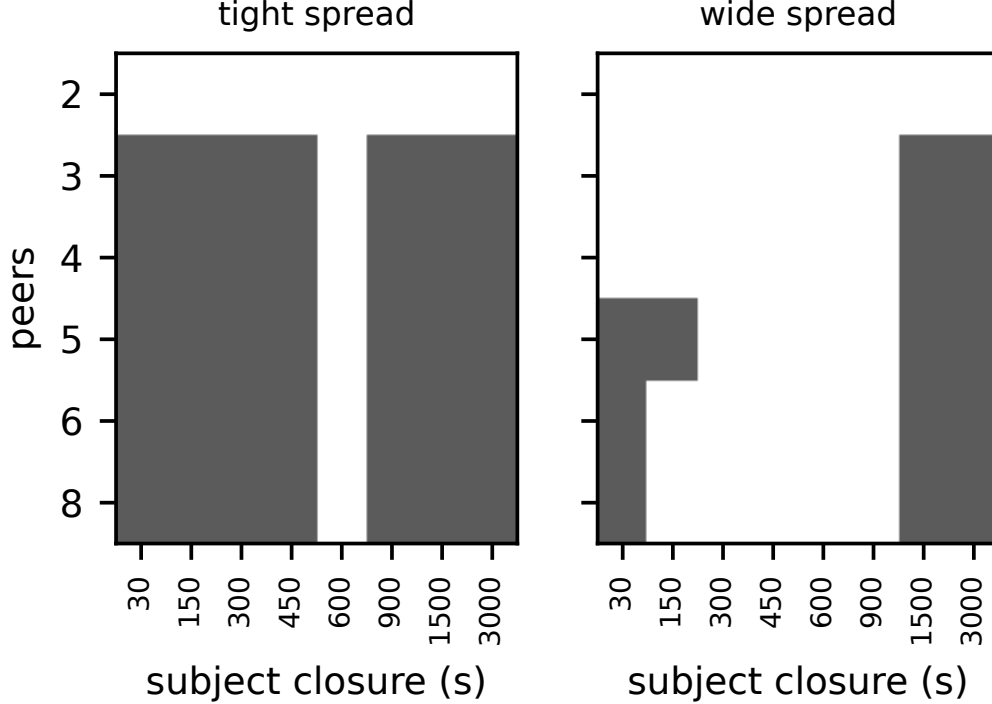


Figure 5: Peer findings by cohort size, spread and subject closure value; dark cells emitted a finding (P01).

repeated 0 times; each run had exactly one decision, one finalization and a verifying receipt. Real process kills, network partitions and database failover were not exercised.

7 External Validation and Failure Analysis

Setup. The unchanged pipeline analysed the UCI-498 incident log [4], a real IT service-desk event log of one organization, with each final assignment group of sufficient size treated as an entity: 50 groups, 22,604 of 24,918 incidents, 47,420 investigation-step proxies from work-state events and 19,656 reassignment-based escalation proxies. The only available outcome is the final service-level flag; SLA labels were loaded only after SAT-SA’s ranking existed and never entered a submission. **This is IT incident data, not SOC data.** The same log has been used to model which factors predict meeting the SLA [41]; we do not predict SLA attainment and use it only as an external outcome.

Table 8: Orchestration overhead on one machine with SQLite (O01, 30 runs per mode).

Mode	Median (s)	p95 (s)	Outside domain (s)	DB calls
Direct	1.276	2.010	0.055	420
Unreviewed (benchmark only)	0.976	1.655	0.029	253
LangGraph	1.433	2.206	0.115	458

Processing excludes the human decision. Graph minus direct: median 0.096 s (95% bootstrap -0.020 to 0.211).

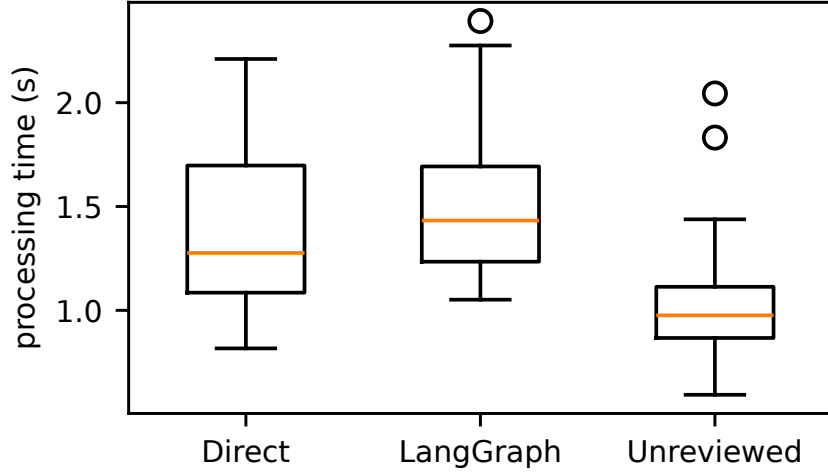


Figure 6: Workflow processing time by execution mode on one machine with SQLite (O01).

Feasibility. All 134,888 submitted rows were accepted (0 rejected) and every group’s analysis completed, with a median of 9 s per group on SQLite.

Negative result. SAT-SA’s risk score was not associated with the SLA-miss rate: Spearman $\rho = -0.11$ (95% bootstrap -0.42 to 0.21 ; Table 10, Figure 7). Slowest median resolution reached $\rho = 0.94$ (0.86 to 0.97), which is expected because an SLA miss is a timeliness outcome; reassignment rate reached 0.37 and volume -0.15 . Among the 12 groups in the top SLA-miss quartile, SAT-SA’s precision@10% was 0.40 (random 0.25, slowest resolution 1.00), and it needed to review 50 groups to find all of them (slowest resolution: 24).

Failure analysis. A diagnostic analysis (X03) on the same data changed no detector, threshold or weight. It attributes the result to four causes. (1) *Construct mismatch (primary)*. The prevalence of fast closures was negatively associated with SLA misses ($\rho = -0.70$, -0.82 to -0.52): on a service desk fast resolution is the goal, whereas SAT-SA treats fast closure of security alerts as possible skipped investigation. The execution-gap dimension, which this signal drives, correlated at -0.41 (-0.66 to -0.11). (2) *Existence-rule saturation*. In total, 4 detector families fired for every group, although their input conditions varied widely—cases without any step 1.7% to 78.4% of cases, medium-or-higher alerts with fewer than two steps 5.2% to 85.9%. A rule that fires on “at least one” qualifying record cannot discriminate submissions with thousands of tickets, and the fusion adds near-constant amounts for these families because it ignores prevalence. Risk still took 49 distinct values and was unrelated to volume ($\rho = 0.02$). (3) *Unavailable constructs*. Of the 7 risk dimensions, 3 had no input data; investigation steps and escalations are proxies (state changes

Table 9: Injected interruptions and recovery (O02, 3 trials per cell).

Interruption	Direct rec.	Direct median (s)	Graph rec.	Graph median (s)
analysis_stage_transient	3/3	0.095	3/3	0.125
analysis_stage_crash	3/3	0.090	3/3	0.124
recommendations_transient	3/3	0.032	3/3	0.056
worker_restart_at_review	3/3	1.337	3/3	1.857
finalization_transient	3/3	1.199	3/3	0.947
finalization_crash	3/3	1.285	3/3	1.376

Every recovered run matched the uninterrupted reference; no completed stage was repeated.

Table 10: External IT incident log (X02b): association with the SLA-miss rate over 50 groups of one organization.

Score	Spearman ρ	95% bootstrap
Incident volume	−0.15	−0.42 to 0.16
Reassignment rate	0.37	0.08 to 0.60
SAT-SA risk score	−0.11	−0.42 to 0.21
Slowest median resolution	0.94	0.86 to 0.97

Top-quartile precision@10%: SAT-SA 0.40, random 0.25, slowest resolution 1.00. Not SOC data.

and reassignments), and monitoring coverage is unavailable. (4) *An adapter artifact*. The log has no step notes; the adapter submits empty notes, which satisfy the repeated-investigation note rule in 39 groups.

The analysis found no temporal or label defect: risk and label cover the same incidents and period; only 3 of 7,907 SLA misses occurred while another group held the ticket; and reassigned incidents missed more often (53.8% versus 21.5%), consistent with the positive reassignment association. The one pipeline defect found—ingestion totals recorded as null—affected bookkeeping only; its fix produced X02b with identical analytical outputs.

Decision and interpretation. No risk-model change was made. A change that raised the correlation with SLA misses would optimize SAT-SA toward a timeliness construct it does not claim to measure, using the evaluation data for tuning. We therefore read X02b and X03 as *feasibility and construct-validity evidence rather than external-effectiveness validation*: the unchanged pipeline processed real workflow data, and on data whose outcome measures a different construct and lacks investigation, escalation and coverage semantics, SAT-SA’s supervisory signals did not transfer. The prevalence-blind fusion of existence rules is a design limitation in SAT-SA’s own domain; addressing it needs SOC development data held out from evaluation.

8 Security and Integrity Evaluation

Threat model. TRUST-SAT targets after-the-fact alteration of the supervisory record: someone with write access to the database or ledger file changes a decision, finding, risk profile, recommendation, source record or receipt after the supervisor decided. It does not address compromise of the signing key, of the running process before finalization, of the operating system, or submission of false records by the monitored organization; it binds what was analysed and decided, not whether the submitted records are true.

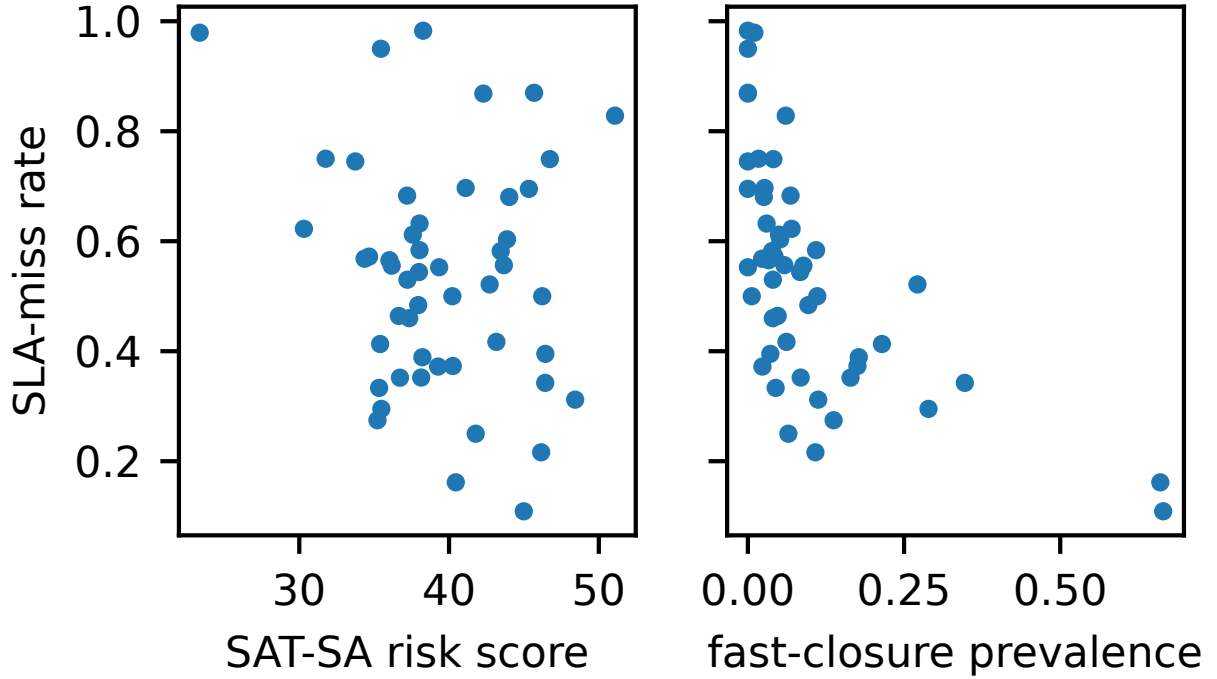


Figure 7: External IT incident log: SAT-SA risk versus SLA-miss rate (left) and fast-closure prevalence versus SLA-miss rate (right), one point per group (X02b, X03). Not SOC data.

Mechanism. Finalization serializes a canonical document of the reviewed state (decision, findings, observations, risk, recommendations, submission records and their provenance), hashes it with SHA3-256 [27], signs the digest with ML-DSA-65 [28], and appends a ledger entry whose hash covers its predecessor, in the spirit of tamper-evident logging [9, 36]. Verification rebuilds the document from the live database, compares digests, checks the decision binding, the signature against the stored public key and the ledger chain.

Mutation matrix (RQ5). On one finalized controlled workflow, each of 14 mutations was applied, verified, restored and re-verified (Table 11). Verification detected 13/13 tested mutations of signed state—decision action and reason, finding, risk, recommendation, observation scope, source provenance, submission record payload, artifact digest, canonical payload, receipt signature, receipt public key and ledger chain. The negative control (1 case), a mutation of an unsigned operational queue field, still verified, as designed. This is evidence that the tested mutations are detected, not a detection rate and not prevention: an attacker able to rewrite the database and re-sign with the service key, or to substitute a key pair consistently across receipts and ledger, is outside the model unless the public key is pinned out of band. Key management and rotation were not evaluated.

Tenant isolation and access. Submission, analysis, review and verification are scoped by tenant; the peer worker uses only same-tenant cohorts; only the supervisor or administrator role can record a decision. These properties are covered by the automated test suite rather than by a dedicated experiment and were not subject to adversarial testing.

Table 11: TRUST-SAT mutation matrix on one controlled workflow (T01).

Mutation	Target	Expected	Observed
decision	satsa_run_review_decisions.action	tampered	tampered
finding	satsa_findings.rationale	tampered	tampered
risk	satsa_run_risk.profile_json	tampered	tampered
recommendation	satsa_run_recommendations.recommendation_json	tampered	tampered
source_provenance	satsa_source_records.locator	tampered	tampered
canonical_payload	satsa_trust_finalizations.canonical_json	tampered	tampered
receipt_signature	satsa_trust_receipts.signature	tampered	tampered
ledger_chain	audit ledger JSONL (last entry prev_hash)	tampered	tampered
decision_reason	satsa_run_review_decisions.reason	tampered	tampered
observation_scope	satsa_observations.scope_json	tampered	tampered
version_record_payload	satsa_version_records.payload_json	tampered	tampered
artifact_digest	satsa_artifacts.sha3_256_digest	tampered	tampered
receipt_public_key	satsa_trust_receipts.public_key	tampered	tampered
operational_queue_field_control	satsa_execution_jobs.lease_owner (unsigned by design)	verified	verified

Detected all tested mutations; this is not a detection rate.

9 Discussion

What the evidence supports. Under controlled conditions the mechanisms behave as designed: declared finding families are emitted with evidence references, the ranking separates generated pathological entities from random and volume orderings, validation follows its declared contract, the tested integrity mutations are detected, and the evaluated interruptions recover without duplicated decisions. These are mechanism-level claims. On independent real data the pipeline is feasible end to end.

What it does not support. It does not show that SAT-SA improves supervision. Simple rules tie the fast-closure detector and nearly match the prioritization; the controlled data and labels are SAT-SA’s own; the only independent outcome available was a different construct, and there SAT-SA’s risk showed no association. No supervisor used the system in a study, and no expert labelled findings. The honest reading is that SAT-SA is a working, inspectable pipeline whose *usefulness* is untested.

Why the simple baselines matter. The closure-speed heuristic tied or nearly tied SAT-SA in most populations, which is consistent with a generator whose pathological profile includes fast closures (we did not isolate the cause). More elaborate workers can only earn their place against data where pathologies are not separable by one rate; the ablation’s finding that four workers *lowered* population recall points the same way. For a supervisor, a small set of transparent rates may be a reasonable first instrument, with record-level findings as the explanation layer rather than the ranking signal.

Design lessons from the negative results. Three design properties surfaced. (i) Existence rules plus confidence-only fusion saturate on large submissions; prevalence-aware scoring is a candidate intervention, to be developed on held-out SOC data rather than on UCI-498. (ii) All-or-nothing validation protects analysis from inconsistent data but turns modest record loss into rejection of a whole period. (iii) No period, recency or consistency checks exist, so stale and contradictory records pass silently—a gap for any supervisory use where submissions are adversarial.

Role of orchestration and of the human. The analytics are deterministic; LangGraph provides checkpointed sequencing and a review interrupt, at a small cost on this workload, and does not make analytical decisions. SAT-SA is decision support: the supervisor decides, and TRUST-SAT records what was decided on which evidence. Automation bias [32] is a real risk for such tools and was not studied.

Contribution strength. The empirical findings, including the negative ones, and the reproducibility infrastructure are the most defensible contributions. The integrity layer is an integration of standard primitives. The application framing is a low-confidence candidate: our literature search was structured but not systematic, and it found close prior work on automated, record-based assessment of incident handling for auditors [30].

10 Limitations and Threats to Validity

Construct validity. Controlled labels are construction labels written by the system’s authors; they encode what scenarios were built to contain. The external outcome (SLA miss) measures timeliness, not supervisory execution quality, and investigation and escalation are proxies there. Risk scores have no validated meaning as probabilities or severities.

Internal validity. Populations for prioritization and ablation come from SAT-SA’s own generator, which injects the behaviours its detectors target, favouring SAT-SA. Precision depends on database layout (shared versus isolated). Detector thresholds were set by design, not fitted; we made no changes on evaluation data, but they were also never tuned on independent development data.

External validity. There is no SOC data from a real organization. The external dataset is one IT service desk. Generated populations have 20 entities, making top- k estimates coarse. The ablation population analysis uses five seeds and is exploratory.

Statistical conclusion validity. Intervals are descriptive, seeded and uncorrected across many comparisons; no hypothesis test is made. Orchestration measurements are repeated runs on one machine and do not generalize across hardware, databases or load. Recovery was tested with injected exceptions at worker-method boundaries, not real process kills, partitions or database failover.

Human factors. The human evaluation protocol is ready but **the study was not executed**; there are no participants and no usability or decision-quality results. The expert label pipeline is ready, but **no expert-labelled data exist**.

Security. Integrity results cover 13 tested mutations on one workflow; key compromise, key management, insider re-signing and false submissions are out of scope. Tenant isolation was not tested adversarially.

Deployment. All measurements used SQLite and local storage on one machine. The local API and worker processes passed 18 HTTP smoke checks (0 failed, 0 not run). Docker was not installed, so container images and the compose topology were not executed; PostgreSQL was not live-tested

Table 12: Deployment verification status and runtime characteristics.

Layer	Status
API + worker processes (SQLite, local storage)	local HTTP smoke 18/18 checks passed
Container images and compose topology	configured; not executed (Docker unavailable)
PostgreSQL	implemented; not live-tested
S3-compatible storage (SeaweedFS)	configured; not executed
CI topology job	configured; not executed
Hosted deployment	not executed
Workflow processing (O01, direct)	median 1.276 s; finalization 0.288 s; verification 0.062 s

(no connection string was available); SeaweedFS object storage and the CI topology job were not executed; no hosted deployment exists (Table 12). No claim of production readiness or scale is made.

11 Reproducibility

Evidence chain. Each reported number is a `\V{claim-id}` macro generated by the paper data layer from a canonical bundle in the evidence freeze `satsa-evidence-freeze-v2`; the build verifies each bundle’s hashes against the freeze before reading it. Tables and figures are generated the same way and record their source bundles and manifest hashes. An audit script regenerates paper data, tables and figures and compares them byte for byte with the committed files, rejects undefined macros and hand-typed decimals, checks that every citation is a verified row of the literature matrix, and scans for prohibited claim wording. The package is archived as a write-once publication snapshot that records the hash of the freeze it was generated from and the hash of every file.

Reproduction levels. We classify what has actually been demonstrated:

- *Level 1, artifact verification (demonstrated)*: the freeze verifier recomputes every recorded hash; it has passed in the working repository and in a fresh clone, and a mutation drill showed that edited manifests, raw results, metrics and configurations are rejected.
- *Level 2, result regeneration (demonstrated)*: paper tables, figures and values regenerate byte-identically from the frozen bundles, and the freeze’s exports regenerate identically.
- *Level 3, experiment reproduction (demonstrated for deterministic experiments)*: re-running the integrity mutation matrix (T01) and the peer sweep (P01) from the recorded code under new experiment identifiers reproduced their analytical outputs; timing-based experiments reproduce only in distribution.
- *Level 4, environment reproduction (not demonstrated)*: a container image and compose topology exist but were not executed; all runs used one Windows machine with the project’s Python dependencies.
- *Level 5, external-data reproduction (demonstrated once)*: the external experiment was executed twice from the public dataset (X02, since superseded, and X02b, at different commits) with identical analytical outputs; it has not been reproduced by a third party.

Commands. All commands are Python scripts in the repository’s `scripts` directory. Level 1 runs `verify_evidence_freeze.py` on the freeze; Level 2 runs `build_paper_assets.py` and then `audit_paper.py`; Level 3 re-runs the experiment runners with each bundle’s recorded configuration. The supplementary material lists the full commands, seeds, dataset provenance and what cannot be reproduced.

Code, data and artifact availability. The SAT-SA source code, experiment runners, evidence freeze, paper data layer and the literature-search scripts are in the project repository under the MIT licence (<https://github.com/PrathamKapoor/SAT-SA-with-PQC>); the commit that contains this manuscript and the publication snapshot is identified in the supplementary material. All controlled data are synthetic and regenerate from the recorded seeds and configurations. The external dataset [4] is public under a Creative Commons Attribution (CC BY) licence and is not redistributed; the experiment downloads it and verifies its checksum. No personal data, no data from a real SOC and no human-participant data were used.

12 Conclusion

SAT-SA turns the operational records a monitored SOC submits into evidence-cited supervisory findings and priorities, keeps the decision with a human supervisor and binds that decision to the analysed state. A frozen, hash-verified evaluation shows the mechanisms working under controlled conditions and the pipeline running on real external data. It also shows where they fall short: simple rules match much of the controlled performance, stale and contradictory evidence passes silently, and on an IT incident log the supervisory risk did not track the only outcome available, mainly because that outcome measures a different construct. The next evidence needed is not more controlled experiments but SOC records with independent outcomes, expert-labelled findings and a study with supervisors.

References

- [1] Enoch Agyepong, Yulia Cherdantseva, Philipp Reinecke, and Pete Burnap. Challenges and performance metrics for security operations center analysts: a systematic review. *Journal of Cyber Security Technology*, 4(3):125–152, 2020. doi: 10.1080/23742917.2019.1698178.
- [2] Enoch Agyepong, Yulia Cherdantseva, Philipp Reinecke, and Pete Burnap. A systematic method for measuring the performance of a cyber security operations centre analyst. *Computers & Security*, 124:102959, 2023. doi: 10.1016/j.cose.2022.102959.
- [3] Bushra A. Alahmadi, Louise Axon, and Ivan Martinovic. 99% false positives: A qualitative study of SOC analysts’ perspectives on security alarms. In *31st USENIX Security Symposium*, pages 2783–2800, 2022. URL <https://www.usenix.org/conference/usenixsecurity22/presentation/alahmadi>.
- [4] C. Amaral, M. Fantinato, and S. Peres. Incident management process enriched event log. UCI Machine Learning Repository, CC BY 4.0, 2018. URL <https://doi.org/10.24432/C57S4H>.
- [5] Richard J. Bolton and David J. Hand. Statistical fraud detection: A review. *Statistical Science*, 17(3):235–255, 2002. doi: 10.1214/ss/1042727940.

- [6] Dirk Broeders and Jermy Prenio. Innovative technology in financial supervision (suptech) – the experience of early users. FSI Insights on policy implementation 9, Bank for International Settlements, Financial Stability Institute, 2018. URL <https://www.bis.org/fsi/publ/insights9.htm>.
- [7] Josep Carmona, Boudewijn van Dongen, Andreas Solti, and Matthias Weidlich. *Conformance Checking: Relating Processes and Models*. Springer, 2018. doi: 10.1007/978-3-319-99414-7.
- [8] Daiki Chiba, Mitsuaki Akiyama, Yuto Otsuki, Hiroki Hada, Takeshi Yagi, Tobias Fiebig, and Michel van Eeten. DomainPrio: Prioritizing domain name investigations to improve SOC efficiency. *IEEE Access*, 10:34352–34368, 2022. doi: 10.1109/ACCESS.2022.3161636.
- [9] Scott A. Crosby and Dan S. Wallach. Efficient data structures for tamper-evident logging. In *18th USENIX Security Symposium*, 2009. URL <https://www.usenix.org/conference/usenixsecurity09/technical-sessions/presentation/efficient-data-structures-tamper-evident>.
- [10] Bradley Efron and R. J. Tibshirani. *An Introduction to the Bootstrap*. Chapman & Hall, 1993.
- [11] Diogo R. Ferreira and Miguel Mira da Silva. Using process mining for ITIL assessment: A case study with incident management. In *13th Annual UKAIS Conference*, 2008.
- [12] Joonas Forsberg and Tapio Frantti. Technical performance metrics of a security operations center. *Computers & Security*, page 103529, 2023. doi: 10.1016/j.cose.2023.103529.
- [13] Scott Freitas, Jovan Kalajdjieski, Amir Gharib, and Robert McCann. AI-driven guided response for security operation centers with Microsoft Copilot for Security, 2024. URL <https://arxiv.org/abs/2407.09017>.
- [14] Scott Freitas, Amir Gharib, and Maayan Magenheimer. Adaptive incident prioritization for security operations at scale, 2026. URL <https://arxiv.org/abs/2607.16963>.
- [15] Somchart Fugkeaw, Neeranuch Jitkhajornwanich, Piroon Mongkolchukaie, Natapat Rouengsamai, and Nutkamol Pornpinyamad. Optimized post-quantum attribute-based logging for real-time and tamper-evident cloud forensics. *IEEE Transactions on Cloud Computing*, 14(2):1098–1114, 2026. doi: 10.1109/TCC.2026.3681599.
- [16] Haula Sani Galadima, Cormac Doherty, and Rob Brennan. Graph analysis of incident response process activities and communications. In *Availability, Reliability and Security. ARES 2026 International Workshops*, Lecture Notes in Computer Science, pages 407–425. Springer, 2026. doi: 10.1007/978-3-032-35579-9_22.
- [17] Gorka Guardiola-Múzquiz and Enrique Soriano-Salvador. SealFSv2: combining storage-based and ratcheting for tamper-evident logging. *International Journal of Information Security*, 22(2):447–466, 2023. doi: 10.1007/s10207-022-00643-1.
- [18] Wajih Ul Hassan, Shengjian Guo, Ding Li, Zhengzhang Chen, Kangkook Jee, Zhichun Li, and Adam Bates. NoDoze: Combatting threat alert fatigue with automated provenance triage. In *Network and Distributed System Security Symposium (NDSS)*, 2019. URL https://www.ndss-symposium.org/wp-content/uploads/2019/02/ndss2019_03B-1-3_UlHassan_paper.pdf.

- [19] Fatemeh Jalalvand, Mohan Baruwal Chhetri, Surya Nepal, and Cécile Paris. Alert prioritisation in security operations centres: A systematic survey on criteria and methods. *ACM Computing Surveys*, 57(2):42, 2024. doi: 10.1145/3695462.
- [20] Fatemeh Jalalvand, Mohan Baruwal Chhetri, Surya Nepal, and Cécile Paris. Adaptive alert prioritisation in security operations centres via learning to defer with human feedback, 2025. URL <https://arxiv.org/abs/2506.18462>.
- [21] Kalervo Järvelin and Jaana Kekäläinen. Cumulated gain-based evaluation of IR techniques. *ACM Transactions on Information Systems*, 20(4):422–446, 2002. doi: 10.1145/582415.582418.
- [22] Faris Bugra Kokulu et al. Matched and mismatched SOC: A qualitative study on security operations center issues. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 1955–1970, 2019. doi: 10.1145/3319535.3354239.
- [23] LangChain. LangGraph documentation: Persistence and durable execution. <https://docs.langchain.com/oss/python/langgraph/durable-execution>, 2026. Accessed 2026-09-27.
- [24] Christophe Leys, Christophe Ley, Olivier Klein, Philippe Bernard, and Laurent Licata. Detecting outliers: Do not use standard deviation around the mean, use absolute deviation around the median. *Journal of Experimental Social Psychology*, 49(4):764–766, 2013. doi: 10.1016/j.jesp.2013.03.013.
- [25] Luc Moreau and Paolo Missier. PROV-DM: The PROV data model. W3C Recommendation, 30 April, 2013. URL <https://www.w3.org/TR/prov-dm/>.
- [26] Andrew Morin and Wellington Gwavava. Mismatched SOC: A case study of cybersecurity goal incongruity within an academic SOC. In *Proceedings of the 2025 Workshop on Security Operation Center Operations and Construction (WOSOC)*. Internet Society, 2025. doi: 10.14722/wosoc.2025.23013.
- [27] National Institute of Standards and Technology. SHA-3 standard: Permutation-based hash and extendable-output functions. Federal Information Processing Standards Publication FIPS 202, NIST, 2015.
- [28] National Institute of Standards and Technology. Module-lattice-based digital signature standard. Federal Information Processing Standards Publication FIPS 204, NIST, 2024.
- [29] Riccardo Paccagnella, Pubali Datta, Wajih Ul Hassan, Adam Bates, Christopher W. Fletcher, Andrew Miller, and Dave Tian. Custos: Practical tamper-evident auditing of operating systems using trusted execution. In *Network and Distributed System Security Symposium (NDSS)*. Internet Society, 2020. doi: 10.14722/ndss.2020.24065.
- [30] Alessandro Palma, Giacomo Acitelli, Andrea Marrella, Silvia Bonomi, and Marco Angelini. A compliance assessment system for incident management process. *Computers & Security*, 146: 104070, 2024. doi: 10.1016/j.cose.2024.104070.
- [31] Alessandro Palma, Nicola Bartoloni, and Marco Angelini. BenchIMP: A benchmark for quantitative evaluation of the incident management process assessment. In *Proceedings of the 19th International Conference on Availability, Reliability and Security (ARES)*, pages 1–12, 2024. doi: 10.1145/3664476.3664504.

- [32] Raja Parasuraman and Dietrich H. Manzey. Complacency and bias in human use of automation: An attentional integration. *Human Factors*, 2010. doi: 10.1177/0018720810376055.
- [33] Martin Rosso, Michele Campobasso, Ganduulga Gankhuyag, and Luca Allodi. SAIBERSOC: Synthetic attack injection to benchmark and evaluate the performance of security operation centers. In *Annual Computer Security Applications Conference (ACSAC)*, pages 141–153, 2020. doi: 10.1145/3427228.3427233.
- [34] A. Rozinat and W. M. P. van der Aalst. Conformance checking of processes based on monitoring real behavior. *Information Systems*, 33(1):64–95, 2008. doi: 10.1016/j.is.2007.07.001.
- [35] Daniel Schlette, Manfred Vielberth, and Günther Pernul. CTI-SOC2M2 – the quest for mature, intelligence-driven security operations and incident response capabilities. *Computers & Security*, 111:102482, 2021. doi: 10.1016/j.cose.2021.102482.
- [36] Bruce Schneier and J. Kelsey. Secure audit logs to support computer forensics. *ACM Transactions on Information and System Security*, 2(2):159–176, 1999. doi: 10.1145/317087.317089.
- [37] Ankit Shah, Rajesh Ganesan, Sushil Jajodia, and Hasan Cam. A two-step approach to optimal selection of alerts for investigation in a CSOC. *IEEE Transactions on Information Forensics and Security*, 14(7):1857–1870, 2019. doi: 10.1109/TIFS.2018.2886465.
- [38] Iman Sharafaldin, Arash Habibi Lashkari, and Ali A. Ghorbani. Toward generating a new intrusion detection dataset and intrusion traffic characterization. In *Proceedings of the 4th International Conference on Information Systems Security and Privacy (ICISSP)*, pages 108–116, 2018. doi: 10.5220/0006639801080116.
- [39] Sathya Chandran Sundaramurthy, Alexandru G. Bardas, Jacob Case, Xinming Ou, Michael Wesch, John McHugh, and S. Raj Rajagopalan. A human capital model for mitigating security analyst burnout. In *Eleventh Symposium On Usable Privacy and Security (SOUPS 2015)*, pages 347–359, 2015. URL <https://www.usenix.org/conference/soups2015/proceedings/presentation/sundaramurthy>.
- [40] Sathya Chandran Sundaramurthy, John McHugh, Xinming Ou, Michael Wesch, Alexandru G. Bardas, and S. Raj Rajagopalan. Turning contradictions into innovations or: How we learned to stop whining and improve security operations. In *Twelfth Symposium on Usable Privacy and Security (SOUPS 2016)*, 2016. URL <https://www.usenix.org/conference/soups2016/technical-sessions/presentation/sundaramurthy>.
- [41] Ajaya K. Swain and Valeria R. Garza. Key factors in achieving service level agreements (SLA) for information technology (IT) incident resolution. *Information Systems Frontiers*, 25(2): 819–834, 2023. doi: 10.1007/s10796-022-10266-5.
- [42] Shahroz Tariq, Mohan Baruwat Chhetri, Surya Nepal, and Cecile Paris. Alert fatigue in security operations centres: Research challenges and opportunities. *ACM Computing Surveys*, 57(9):224, 2025. doi: 10.1145/3723158.
- [43] Jack Tilbury and Stephen Flowerday. Automation bias and complacency in security operation centers. *Computers*, 13(7):165, 2024. doi: 10.3390/computers13070165.
- [44] Wil M. P. van der Aalst. *Process Mining: Data Science in Action*. Springer, 2 edition, 2016. doi: 10.1007/978-3-662-49851-4.

- [45] Wil M. P. van der Aalst and A. K. A. de Medeiros. Process mining and security: Detecting anomalous process executions and checking process conformance. *Electronic Notes in Theoretical Computer Science*, 121:3–21, 2005. doi: 10.1016/j.entcs.2004.10.013.
- [46] Rob van Os. SOC-CMM: Designing and evaluating a tool for measurement of capability maturity in security operations centers. Master’s thesis, Luleå University of Technology, 2016. URL <https://ltu.diva-portal.org/smash/get/diva2:1033727/FULLTEXT02.pdf>.
- [47] Manfred Vielberth, Fabian Böhm, Ines Fichtinger, and Günther Pernul. Security operations center: A systematic study and open challenges. *IEEE Access*, 8:227756–227779, 2020. doi: 10.1109/ACCESS.2020.3045514.
- [48] David J. Weston, David J. Hand, Niall M. Adams, Christopher Whitrow, and Piotr Juszczak. Plastic card fraud detection using peer group analysis. *Advances in Data Analysis and Classification*, 2(1):45–62, 2008. doi: 10.1007/s11634-008-0021-8.